

Third-Party Risk Assessment

MapleCloud Analytics — Simulated Vendor Assessment

Executive Summary

This simulated assessment evaluates the cybersecurity risk associated with a fictional cloud analytics vendor supporting a fictional financial services organization. The assessment reviews governance, access control, data protection, incident response, continuity, subcontractor oversight, vulnerability management, and independent assurance.

Important: All vendors, evidence, findings, risks, and recommendations are fictional and created for portfolio demonstration. This is not a real vendor due-diligence assessment.

Key Findings

Area	Finding	Rating
Privileged access	MFA assurance for privileged vendor access requires remediation.	Critical
Data protection	Encryption evidence is incomplete and requires validation.	High
Business continuity	Continuity and disaster-recovery evidence is incomplete.	High
Subprocessors	Subprocessor oversight requires stronger documentation.	High
Incident response	Notification and escalation expectations should be formalized.	Medium

Risk Treatment

The portfolio assessment uses a 5×5 likelihood-and-impact scoring method to prioritize remediation. This scoring approach is a project methodology and is not presented as a prescribed requirement of NIST or ISO/IEC 27001.

The simulated outcome is conditional approval pending remediation of material findings. In a real engagement, the final decision would depend on organizational risk appetite, contractual requirements, evidence quality, and formal risk acceptance authority.

Remediation Roadmap

Timeframe	Priority Action
0–30 days	Require MFA for privileged vendor access and validate encryption controls.
31–60 days	Review BCP/DR testing and formalize subprocessor oversight.
61–90 days	Formalize incident notification SLAs and escalation requirements.

Skills Demonstrated

Third-party risk assessment, control-gap analysis, risk scoring, vendor due diligence, remediation planning, executive reporting, and GRC documentation.

References

NIST Cybersecurity Framework 2.0; NIST SP 800-161 Rev. 1; ISO/IEC 27001:2022. Accessed for portfolio methodology and control context.